A L A - 3

Cyber Deception Chronicles

Social Engineering Attacks & Major Security Breaches

Name: **Jayveer Sinh**

Enrollment No: **241105060042**

Course: DETIT15214 - Cryptography and Network Security

Session: GMIU-2026-27 (ODD) | Sem 5 | Class B

Gyanmanjari Innovative University

What is Social Engineering?

Hacking the human, not the machine

Social engineering manipulates people into revealing confidential information or performing actions that break security - by exploiting trust, fear, urgency and curiosity.

Why it works

Authority

Pretending to be boss / IT / bank

Urgency

"Act now or account closes"

Trust

Familiar names, logos, colleagues

Greed / Curiosity

Free gifts, "leaked" files

~68% of breaches involve a human element (Verizon DBIR 2024)

#1 entry point: phishing & stolen credentials

Minutes is all an attacker needs to build trust

Common Attack Techniques

Phishing, pretexting, baiting and more

Phishing

Fake emails/links that mimic trusted brands to steal logins.

Example: fake bank "KYC update" mail

Pretexting

Attacker invents a believable story/identity to extract data.

Example: "I am from IT, share your OTP"

Baiting

Tempting lure - infected USB or free download - left for victim.

Example: USB marked "Salary 2026"

Vishing / Smishing

Voice calls and SMS used to pressure victims in real time.

Example: fake helpdesk call

Tailgating

Following an authorised person into a restricted area.

Example: "Hold the door please"

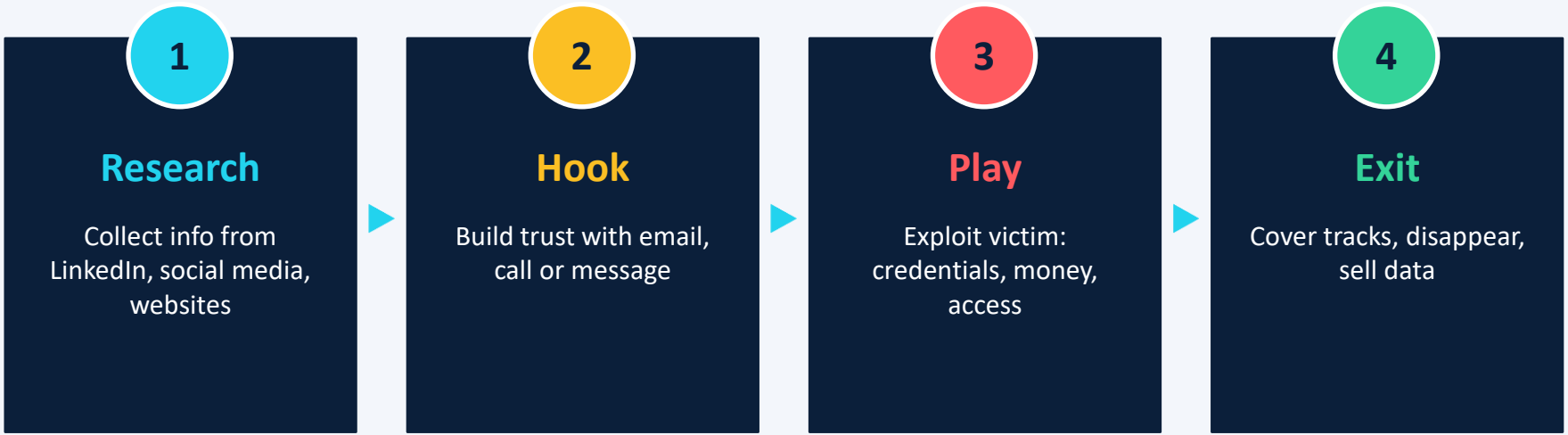
BEC / Spear Phishing

Targeted mails impersonating CEO/vendor to move money.

Example: fake invoice payment

Anatomy of a Social Engineering Attack

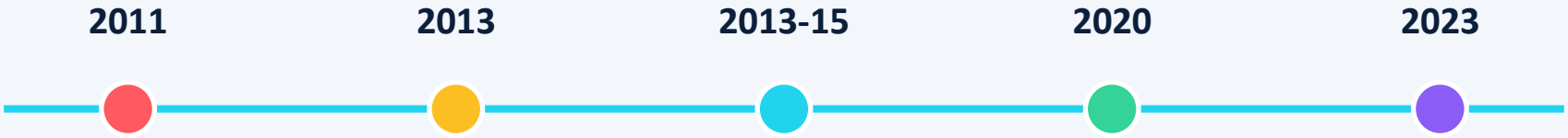
The 4-stage attack lifecycle



Red flags: urgent tone, unknown sender, mismatched URL, request for passwords/OTP, unusual payment or access request.

Major Security Breaches - Timeline

Real-world cases driven by social engineering



RSA SecurID

Phishing mail with infected Excel file

Target

Vendor credentials stolen; ~40M cards

Google & Facebook

Fake invoices; $100M+ lost (BEC)

Twitter

Phone spear-phishing; 130 accounts hit

MGM Resorts

Helpdesk vishing; ~$100M impact

Case Study 1: Twitter Hack (2020)

Vishing + insider tool access

Impact: ~130 accounts targeted, scam tweets from prominent profiles, share price & trust hit

How it happened

- Attackers phoned Twitter employees posing as internal IT support
- Employees were tricked into entering credentials on a fake login page
- Hackers reached internal admin tools and reset account access
- High-profile accounts posted a Bitcoin scam

How it could have been prevented

- Hardware security keys (FIDO2) instead of SMS/OTP
- Strict verification for any internal support call
- Least-privilege access and approval for admin tools
- Regular vishing awareness training

Case Study 2: Target Breach (2013)

Third-party credential theft

Impact: ~40 million cards and 70 million customer records exposed

How it happened

- Phishing email compromised an HVAC vendor (Fazio Mechanical)
- Stolen vendor credentials gave access to Target's network
- Attackers moved to payment systems and installed POS malware
- Alerts from security tools were not acted upon

How it could have been prevented

- Network segmentation between vendor and payment systems
- Multi-factor authentication for vendors
- Vendor security audits and monitoring
- Respond promptly to security alerts

Case Study 3: MGM Resorts (2023)

Helpdesk impersonation

Impact: Operations disrupted for days; estimated ~$100M financial impact

How it happened

- Attacker found an employee on LinkedIn and called the IT helpdesk
- Impersonated the employee to get credentials / MFA reset
- Gained admin access, then deployed ransomware
- Hotels, casinos and digital keys went offline for days

How it could have been prevented

- Strong identity verification before any password or MFA reset
- Call-back to a registered number
- Privileged access management and monitoring
- Social engineering drills for helpdesk teams

Prevention Strategies

Defence in depth: people + process + technology

Awareness Training

Regular phishing simulations and reporting culture

Multi-Factor Auth

Use app/hardware keys - never share OTP

Verify Requests

Call back on known numbers before acting

Email Security

SPF, DKIM, DMARC, spam & link filtering

Least Privilege

Give minimum access, review it often

Incident Response

Report fast, have a tested response plan

Key Takeaways

- Humans are the weakest link - attackers target people first
- Most major breaches began with a simple phishing, call or fake request
- Verify identity, use MFA and apply least privilege
- Security awareness is the strongest and cheapest defence

"Think before you click. Verify before you trust."

References: Verizon DBIR 2024, Twitter/NYDFS report (2020), US Senate Target breach report (2014), Krebs on Security, MGM Resorts SEC filings (2023)